Penetration Test Report

RickdiculouslyEasy

VulnHub vulnerable virtual machine

Assessment type	Controlled-lab penetration test
Target address	192.168.56.112
Attacker environment	Kali Linux (192.168.56.40, as shown in captured SSH evidence)
Assessment date	8–9 November 2026 (dates visible in terminal evidence)
Prepared by	Joshua Sanctus
Evidence supplied	19 screenshots in the accompanying evidence archive

Scope and handling note. This report documents activity against the intentionally vulnerable RickdiculouslyEasy training VM in an isolated lab. The conclusions are limited to the supplied screenshots. Passwords and recovered flag values are not reproduced in the report body; the screenshots may contain challenge-specific material and should be treated as private lab evidence.

Contents

1 Executive Summary **2**

2 Scope, Objective, and Limitations **2**

2.1 Objective . . . 2

2.2 In-scope system . . . 2

2.3 Evidence limitations . . . 2

3 Methodology **3**

4 Technical Findings **3**

4.1 Web directory and content enumeration . . . 3

4.2 Additional web application information disclosure . . . 3

4.3 SSH credential discovery and initial access . . . 4

4.4 Post-access file and archive investigation . . . 4

4.5 Further SSH access as RickSanchez . . . 4

4.6 Root privilege escalation . . . 5

5 Other Challenge Evidence **5**

6 Attack Path Summary **5**

7 Findings and Risk Assessment **6**

8 Recommendations **6**

8.1 Web server and application . . . 6

8.2 SSH and account security . . . 6

8.3 Privilege management . . . 7

9 Conclusion **7**

10 Evidence Register **7**

1 Executive Summary

A penetration test was performed against the VulnHub RickdiculouslyEasy virtual machine at `192.168.56.112`. The supplied evidence demonstrates several exposed services and information-disclosure paths, followed by credential discovery, SSH access, local enumeration, and privilege escalation to root.

The documented attack path involved:

1. Web content discovery against the HTTP service, including inspection of `robots.txt` and a browsable `/passwords/` directory.
2. Discovery of additional information through the web application, including a page described as Morty's Machine Tracer and output containing account information.
3. Recovery of an SSH credential for the `Summer` account using a password wordlist.
4. Inspection of user files and a password-protected archive. A password clue was recovered from the supplied image file, allowing the archive to be opened.
5. Further credential investigation and successful SSH access as `RickSanchez`.
6. Identification of unrestricted sudo privileges for `RickSanchez`, followed by a root shell and access to the root-level proof file.

The screenshots also document several challenge flags exposed through separate services or files. The evidence supports a successful compromise of the target VM and root-level access. It does not include a complete initial port-scan transcript, so this report does not claim a definitive full port inventory.

2 Scope, Objective, and Limitations

2.1 Objective

The objective was to assess the intentionally vulnerable VM, identify exposed services and weaknesses, establish access through available attack paths, and determine whether local privilege escalation was possible.

2.2 In-scope system

- Target: RickdiculouslyEasy
- Target IP address: `192.168.56.112`
- Environment: isolated virtualised lab, as represented by the private address range in the evidence

2.3 Evidence limitations

This report is based on the 19 screenshots supplied in the ZIP archive. The evidence does not contain a complete Nmap output, full HTTP request/response captures, complete command history, or a continuous terminal recording. Consequently:

- Port and service details are reported only where directly visible in the screenshots.

- The exact sequence of every intermediate command and account transition cannot be independently reconstructed.
- No CVSS score is assigned because the evidence is insufficient to establish a complete production-impact context.
- No claim is made about persistence, lateral movement, or impact beyond the lab VM.

3 Methodology

The assessment followed a practical penetration-testing workflow:

1. **Service and web enumeration:** identify reachable web content and inspect exposed paths and application behaviour.
2. **Information gathering:** examine discovered files, web responses, and account-related information for useful clues.
3. **Credential testing:** use the recovered clues to construct a focused candidate list and test SSH authentication in the lab.
4. **Initial access:** authenticate to the target over SSH.
5. **Post-exploitation enumeration:** inspect local users, home directories, files, and privilege configuration.
6. **Privilege escalation:** validate whether the compromised account could obtain root privileges.

4 Technical Findings

4.1 Web directory and content enumeration

The Gobuster screenshot records a directory-enumeration run against `http://192.168.56.112`. The visible results include `/cgi-bin/`, `/passwords/`, and `/robots.txt`. The browser evidence shows that `robots.txt` contained an "under construction" entry, while the `/passwords/` directory exposed an index page with downloadable or viewable files, including `FLAG.txt` and `passwords.html`.

The exposed directory listing and related content created an information-disclosure path. The screenshots also show a flag file being accessed directly under the passwords directory.

Security significance: publicly accessible directories and files can disclose internal naming conventions, credentials or credential hints, and challenge/application data that should not be exposed unintentionally.

4.2 Additional web application information disclosure

The screenshots identify a web page titled "Morty's Machine Tracer Machine". A captured response from this application displays account-related entries, including local system account names and home-directory information. Another screenshot shows a request interacting with the application's CGI path.

The evidence indicates that the application exposed operating-system account information through its response. The screenshots do not provide the server-side source code or the complete HTTP exchange, so the precise implementation flaw cannot be confirmed.

Security significance: returning local account data through a web-facing feature can assist an attacker in selecting usernames and building targeted credential attacks.

4.3 SSH credential discovery and initial access

The supplied Hydra screenshot shows an SSH password-guessing attempt against `192.168.56.112` on TCP port `22222`. It records a valid credential for the `Summer` account. A separate screenshot documents a successful SSH session to the same host and port.

The evidence therefore supports the following:

- SSH was reachable on the non-default port `22222`.
- A valid password for the `Summer` account was recovered through wordlist-based testing.
- The recovered credential was used to establish an SSH session.

The password itself is intentionally omitted from the report text.

Security significance: a weak or guessable password, combined with an SSH service that permits repeated authentication attempts, can enable unauthorised remote access. The screenshot records a substantial number of failed logins before the successful session, illustrating the value of rate limiting and monitoring.

4.4 Post-access file and archive investigation

After obtaining the `Summer` shell, the screenshots show enumeration of local home directories, including `/home/Morty`. The evidence records the presence of a ZIP archive named `journal.txt.zip` and an image named `Safe_Password.jpg`. A strings-based inspection of the image exposed a password hint associated with the archive. The archive was then extracted, and the journal content disclosed an additional challenge clue.

The screenshots also show an attempted file transfer using SCP. Some attempts failed because of path or permission issues, followed by a successful transfer of the archive and image. The exact sequence is retained as shown in the evidence rather than inferred beyond it.

Security significance: sensitive information embedded in files, metadata, or user-accessible directories can undermine otherwise separate authentication boundaries. File permissions should prevent one user from reading another user's sensitive files unless explicitly required.

4.5 Further SSH access as RickSanchez

The evidence shows the creation of a focused password candidate list using Crunch, followed by a Hydra attempt against SSH on port `22222` for the `RickSanchez` account. A separate screenshot confirms a successful SSH login as `RickSanchez`.

The supplied screenshots support the use of clues gathered during the assessment to build a targeted candidate list. They do not clearly expose every candidate or the recovered password in a way that is necessary to reproduce it in this report.

4.6 Root privilege escalation

The final SSH evidence shows a session as `RickSanchez`. The captured `sudo -l` output lists the account as permitted to run commands as root, with the rule `(ALL) ALL`. The screenshot then shows the execution of `sudo su`, followed by a root shell and access to the root-level flag file.

This is a direct privilege-escalation path: a user account with unrestricted sudo permissions can execute commands as root.

Security significance: unrestricted sudo access defeats the intended separation between an ordinary user and the system administrator. In a production environment, it would provide full control of the host to anyone who compromises that account.

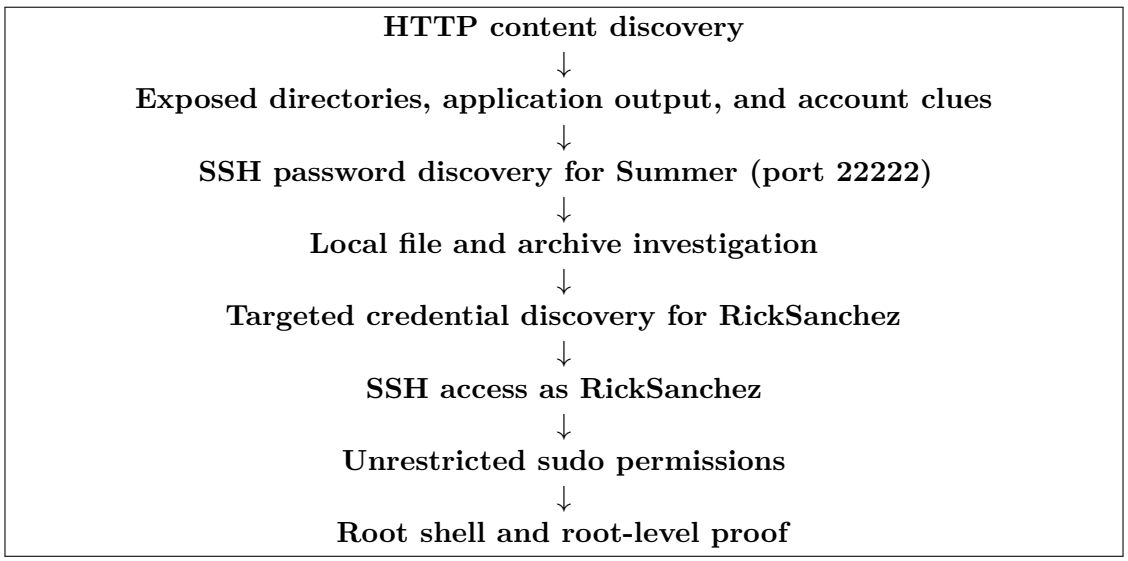
5 Other Challenge Evidence

The screenshots also record challenge flags or proof strings obtained through several services and locations:

- A custom service interaction on port `13337`.
- A service interaction on port `60000`, which returned a banner identifying a half-baked reverse shell and a flag file.
- A web service on port `9090`, which displayed a Fedora-themed login page and a challenge message.
- Additional flags found in web-accessible files and user home directories.

These items are recorded as challenge evidence rather than separate vulnerabilities where the screenshots do not establish the underlying service implementation or security cause. The available material does not include a complete scan output, so the list above must not be interpreted as a comprehensive port inventory.

6 Attack Path Summary



7 Findings and Risk Assessment

Finding	Severity	Evidence-based rationale
Exposed web directories and files	Medium	Directory listing and directly accessible files disclosed content and challenge information.
Web application information disclosure	Medium	The Machine Tracer page returned local account information. The precise server-side cause is not established.
Weak SSH authentication	High	Wordlist-based testing recovered a valid account password on the exposed SSH service.
Sensitive files accessible after user compromise	Medium	User-level access enabled investigation of an archive and an image containing a password clue.
Unrestricted sudo privileges	Critical	The `RickSanchez` account was allowed to execute all commands as root, and root access was demonstrated.

Severity labels are qualitative and reflect the demonstrated lab impact, not a formal CVSS assessment. The root-level finding is rated Critical because it directly enabled complete administrative control of the target VM.

8 Recommendations

8.1 Web server and application

- Disable directory indexing unless it is explicitly required.
- Remove challenge, backup, archive, and diagnostic files from publicly served directories.
- Review `robots.txt`; it is not an access-control mechanism and must not be relied upon to hide sensitive paths.
- Restrict diagnostic and CGI functionality. Do not return local account files, command output, or filesystem details to unauthenticated users.
- Apply server-side input validation and least-privilege execution to any feature that performs lookups or system operations.

8.2 SSH and account security

- Enforce long, unique passwords or use public-key authentication.
- Disable password authentication where operationally feasible.
- Apply rate limiting, authentication throttling, and monitoring for repeated failed logins.
- Alert on unusual authentication patterns and review account lockout policy carefully to avoid denial-of-service side effects.
- Remove unused accounts and ensure that home-directory permissions protect private files.

8.3 Privilege management

- Remove unrestricted sudo permissions from ordinary user accounts.
- Grant only the specific commands required for a documented operational purpose.
- Review sudoers configuration regularly and validate changes with `visudo`.
- Monitor privileged command execution and investigate unexpected use of `sudo su` or root shells.

9 Conclusion

The supplied evidence demonstrates a successful compromise of the RickdiculouslyEasy training VM, culminating in root-level access. The main contributing weaknesses shown are exposed web content, disclosure of local account information, recoverable SSH credentials, sensitive information accessible through user files, and unrestricted sudo permissions.

The most consequential issue was the unrestricted sudo rule assigned to `RickSanchez`, which converted compromise of that account into full host compromise. In a real environment, remediation should prioritise removal of excessive privileges and correction of weak authentication, followed by review of web exposure and sensitive file handling.

10 Evidence Register

All 19 screenshots from the supplied ZIP archive are embedded below. Captions describe only what is visible in each image. Some screenshots contain challenge-specific flag values or credential material; avoid publishing the evidence archive publicly without reviewing and redacting it.

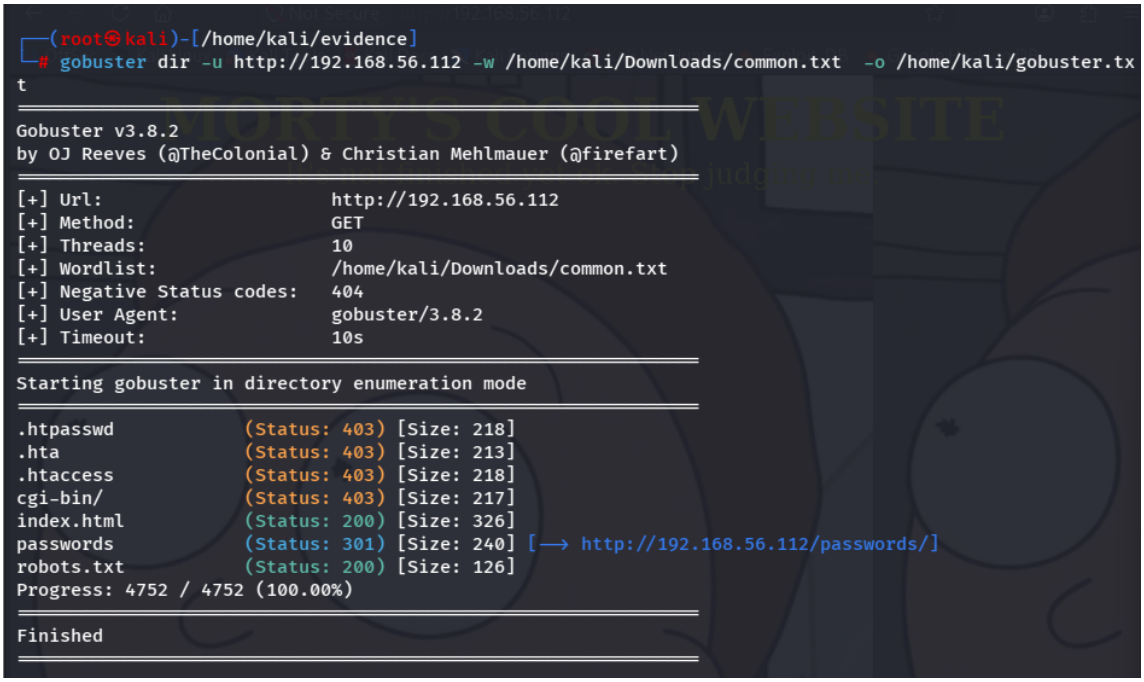


Figure 1: Gobuster directory enumeration against the target web server.

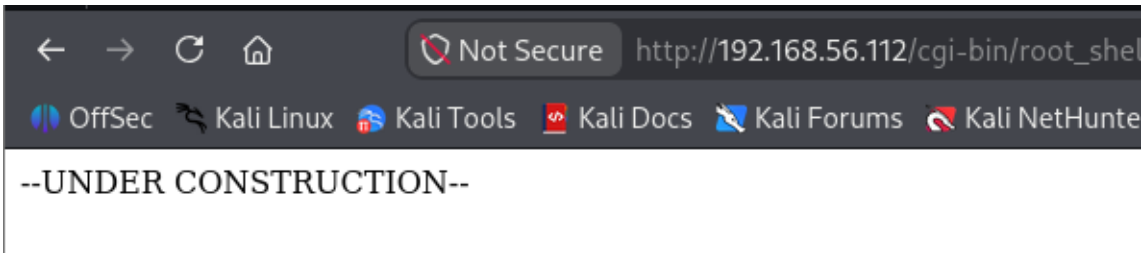


Figure 2: Browser inspection of the target's `robots.txt`.



Figure 3: Browsable index of the `/passwords/` directory.

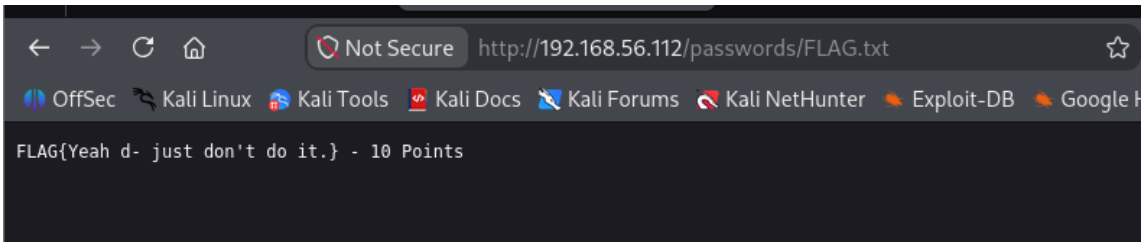


Figure 4: Direct access to a flag file under the passwords directory.

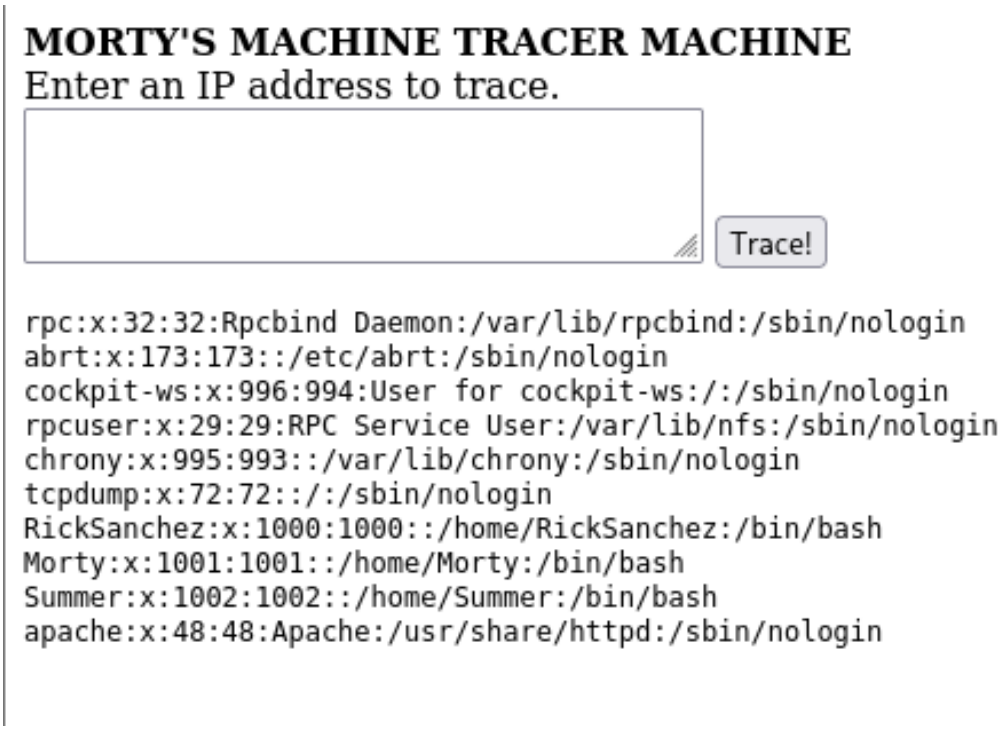


Figure 5: Machine Tracer page displaying account-related system information.

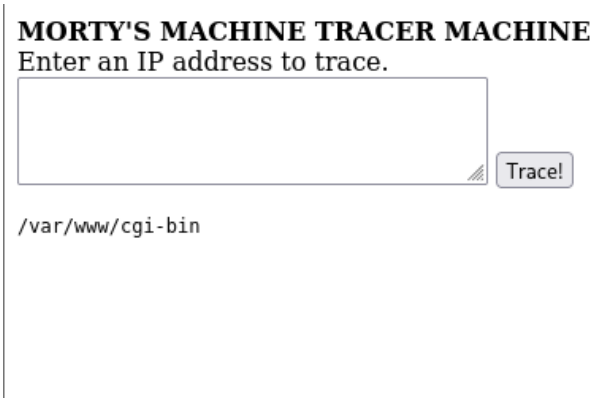


Figure 6: Interaction with the Machine Tracer CGI path.

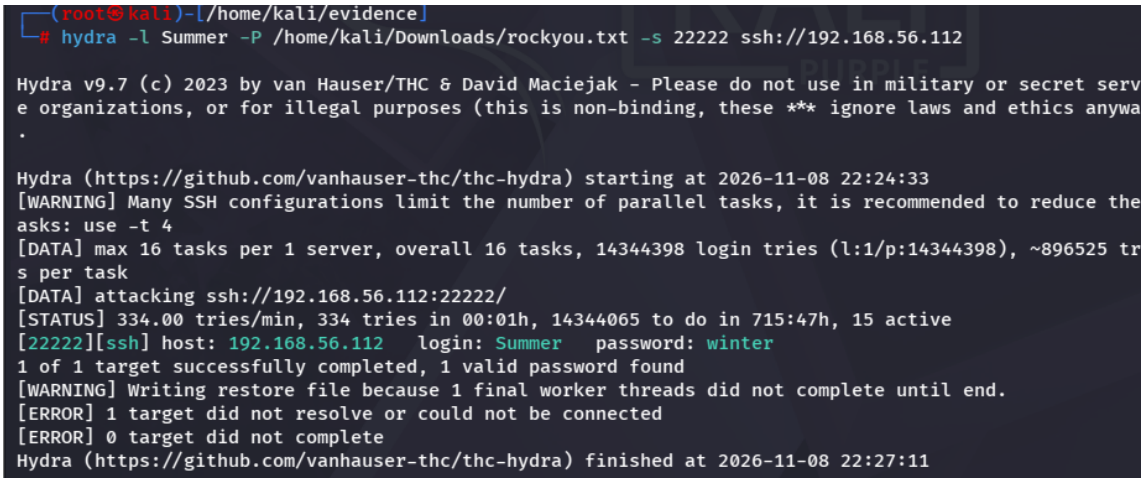


Figure 7: Hydra output showing a valid SSH credential for the Summer account on port 22222.



Figure 8: SCP attempts to retrieve files from the target user's home directory.

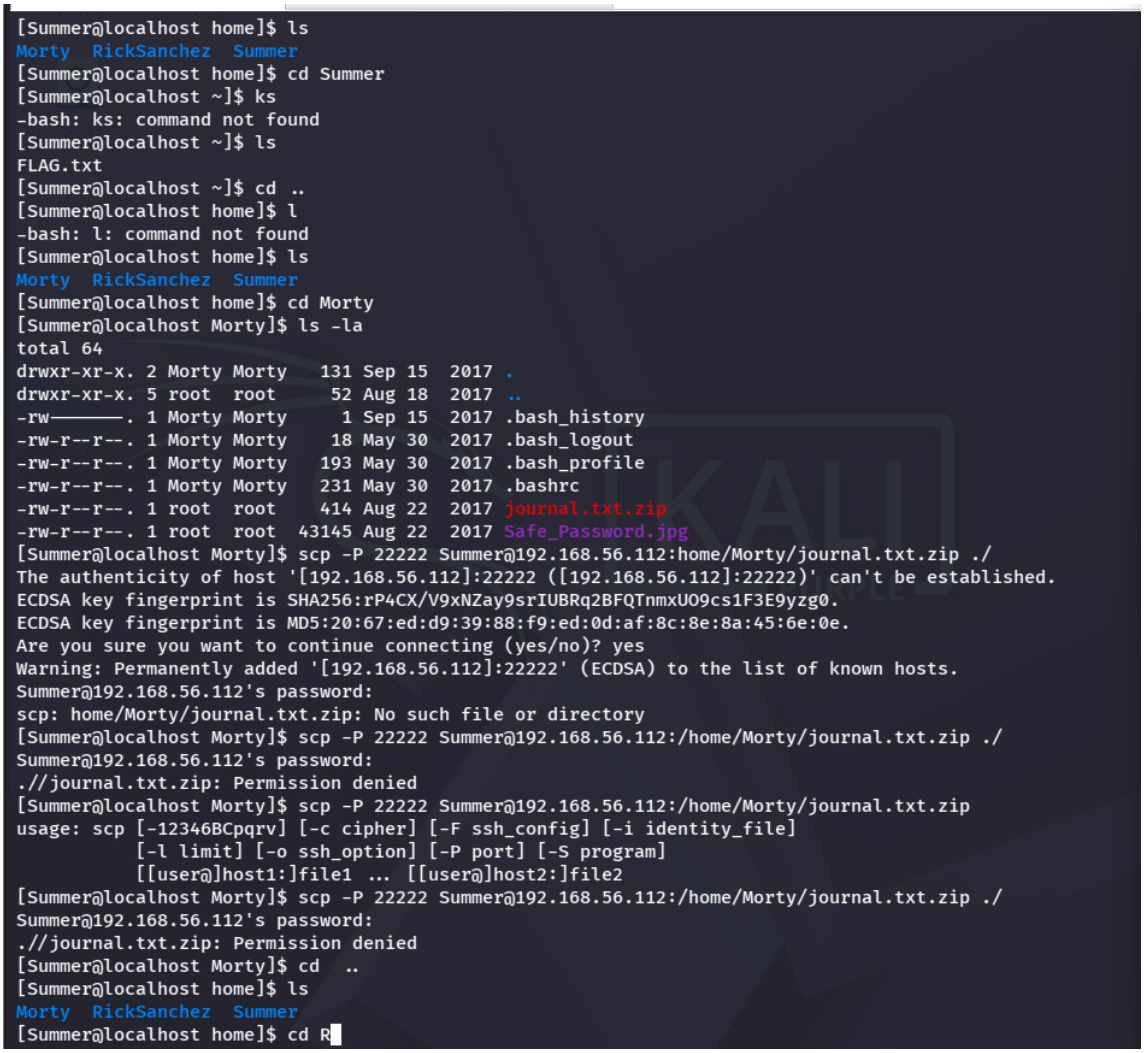


Figure 9: Local enumeration of home directories and files.

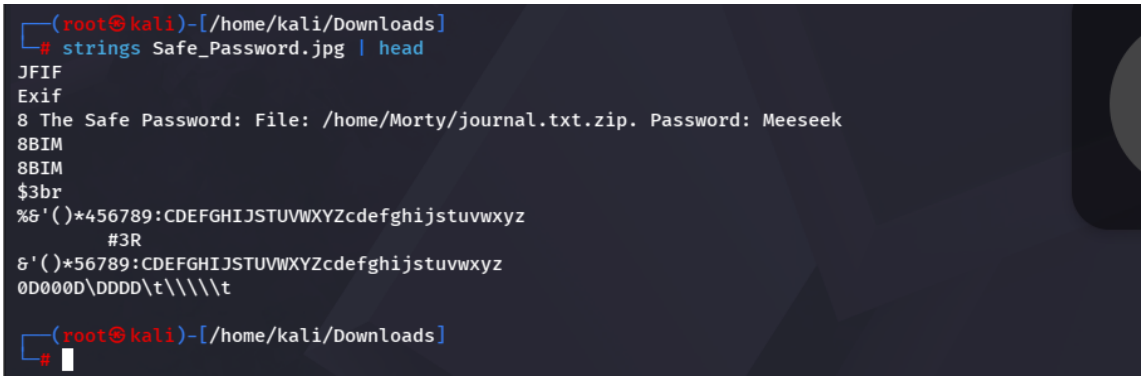


Figure 10: Strings output from the Safe Password image showing an archive password clue.

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# unzip journal.txt.zip
Archive:  journal.txt.zip
[journal.txt.zip] journal.txt password:
  inflating: journal.txt

┌──(root㉿kali)-[/home/kali/Downloads]
└─# cat journal.txt
Monday: So today Rick told me huge secret. He had finished his flask and was on to commercial grade pai
nt solvent. He spluttered something about a safe, and a password. Or maybe it was a safe password... Wa
s a password that was safe? Or a password to a safe? Or a safe password to a safe?

Anyway. Here it is:

FLAG: {131333} - 20 Points

┌──(root㉿kali)-[/home/kali/Downloads]
└─#
```

Figure 11: Extraction and inspection of the journal archive.

```
[Summer@localhost ~]$ head FLAG.txt
FLAG{Get off the high road Summer!} - 10 Points
```

Figure 12: Flag file discovered in the Summer user's home directory.

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# crunch 5 5 -t ,%The > rick-wordlist.txt

crunch 7 7 -t ,%Flesh >> rick-wordlist.txt

crunch 10 10 -t ,%Curtains >> rick-wordlist.txt
Crunch will now generate the following amount of data: 1560 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 260
Crunch will now generate the following amount of data: 2080 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 260
Crunch will now generate the following amount of data: 2860 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 260

┌──(root㉿kali)-[/home/kali/Downloads]
└─# hydra -l RickSanchez -P rick-wordlist.txt ssh://192.168.56.112:22222
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret servic
e organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)
.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-11-08 22:52:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the t
asks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 780 login tries (l:1/p:780), ~49 tries per task
[DATA] attacking ssh://192.168.56.112:22222/
```

Figure 13: Creation of a focused candidate list and subsequent SSH credential testing.

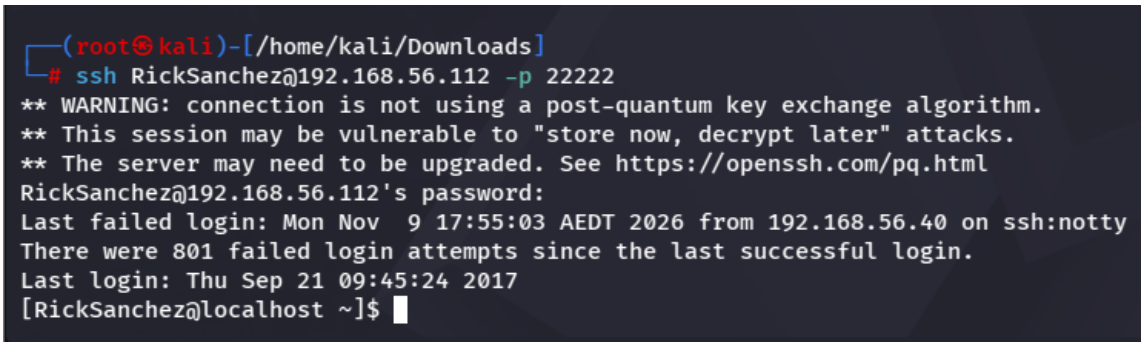


Figure 14: Successful SSH session as RickSanchez on port 22222.

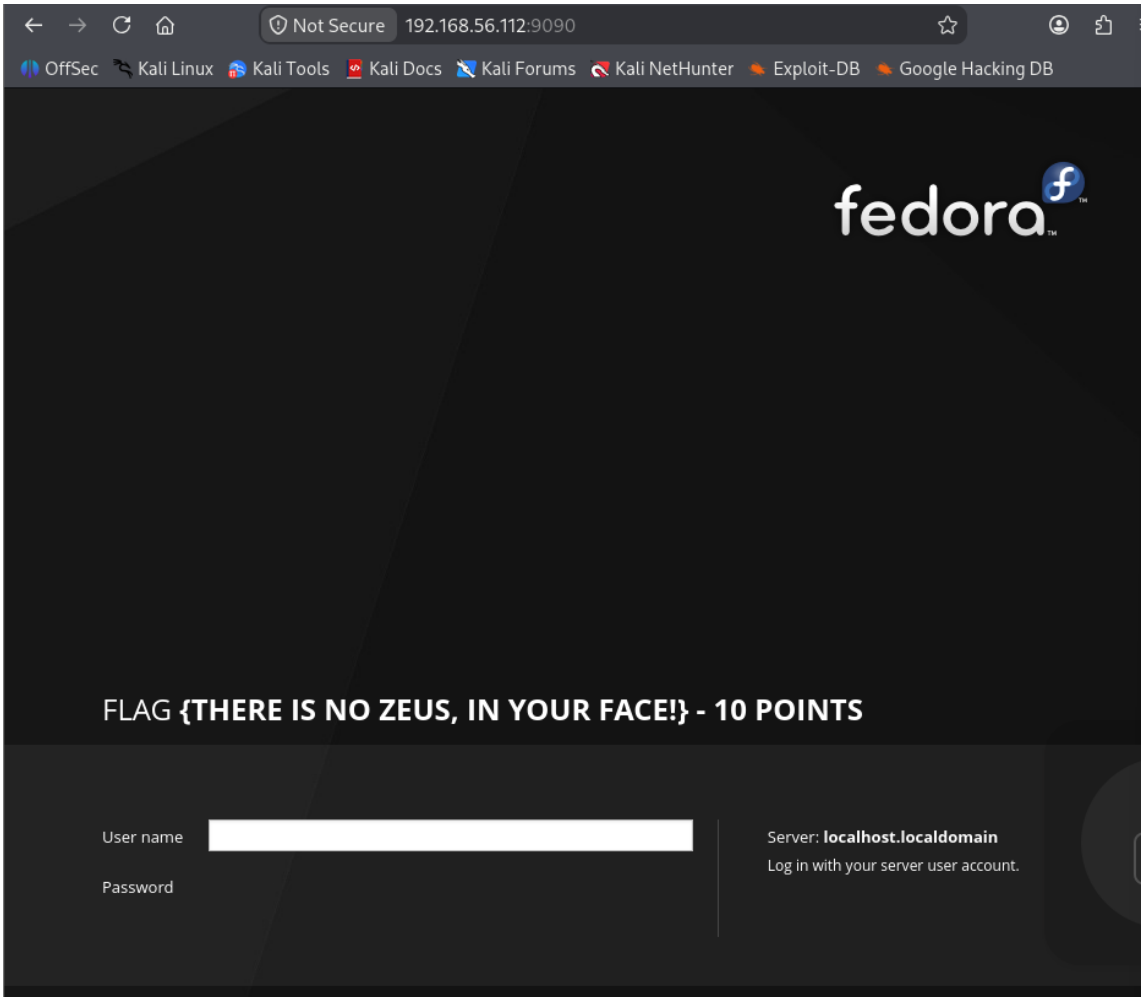


Figure 15: Web page on port 9090 displaying a challenge message.

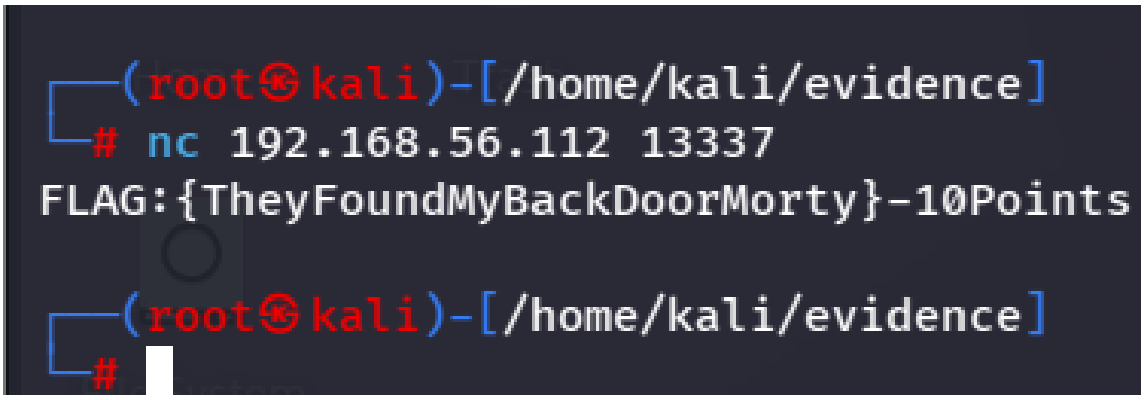


Figure 16: Challenge response captured from port 13337.

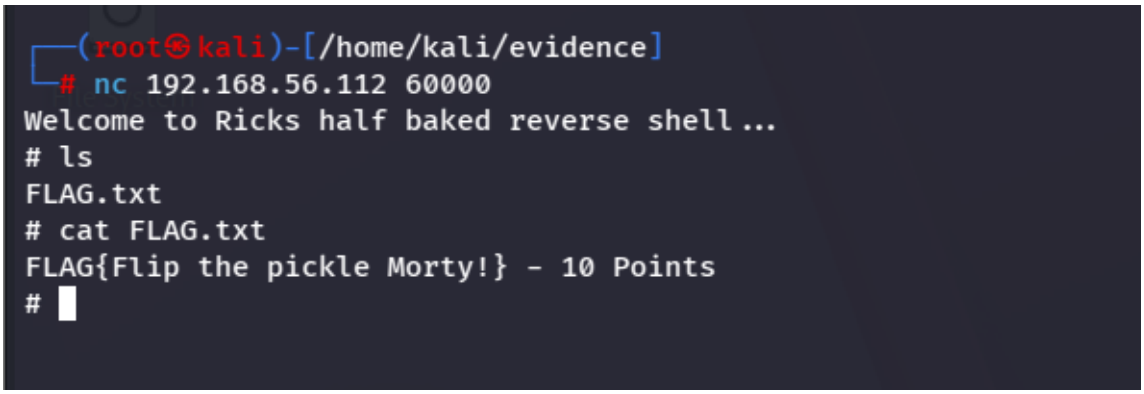


Figure 17: Interaction with the service on port 60000 and retrieval of its flag file.

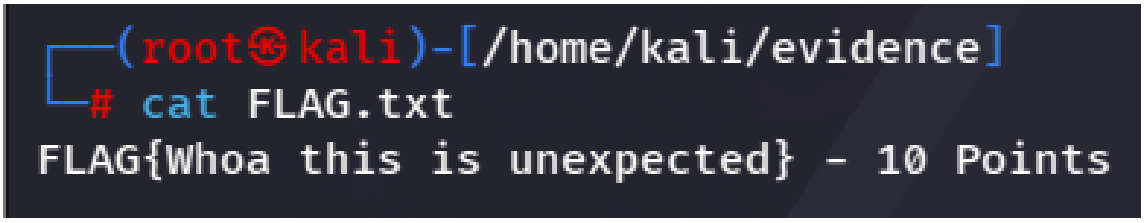


Figure 18: Additional flag file captured from the Kali evidence directory.

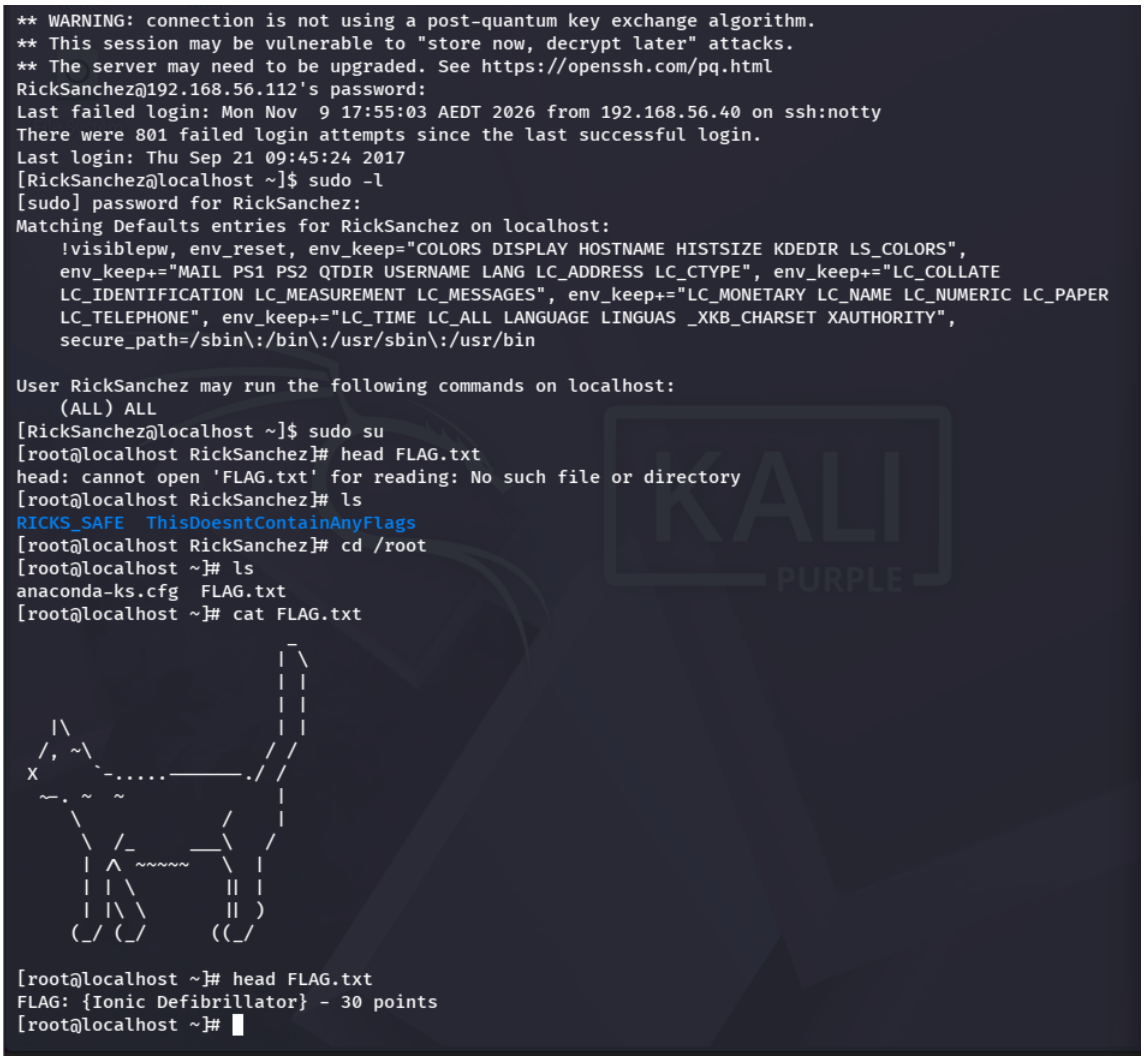


Figure 19: Sudo privilege listing, root-shell acquisition, and root-level proof.